

ActiveState will help software vendors comply with White House mandate

ActiveState is the first open source software platform to offer the crucial element of software supply chain security with the announcement of the availability of open source software attestations. A comprehensive set of recommendations from the National Institute of Standards and Technology (NIST) that has been accepted by the White House includes the ability to receive self-attestation for all third-party software and the capacity to create a software bill of materials (SBOM). A recent White House directive mandates that by June 12, 2023, all essential software that interacts in any way with government data or systems must meet these new security requirements. By September 14, 2023, all software must abide by these stringent requirements.

Most firms do not carefully maintain open source provenance. While some very large organisations may have the systems and procedures in place to comply with the mandate, this will be a costly process for everyone else. They run a very real risk of missing the White House deadline for compliance as a result.

By automatically generating each artefact from source code via a cloud-scale vendoring system, the ActiveState platform provides transparent provenance and custody chain, certifications for each package, and an SBOM that lists every piece of software. It helps manage and resolve complex open source dependencies automatically.

By eliminating the time, complexity, and danger associated with adopting open source, software developers may safeguard their supply chain and satisfy even the most demanding security standards by using ActiveState as a trusted vendor.

The S3 buckets may also store ‘secrets’, which include authentication keys, access tokens, and API keys, in addition to application data. These files may be source code or configuration files. Threat actors may be given much wider access to other services or even the company’s corporate network if these secrets are unlawfully disclosed and made available to them.



Security researcher Eilon Harel learned that there are no tools for detecting unintentional data breaches during an exercise looking at SEGA’s recent asset exposure. As a result, he decided to build his own automated scanner and publish it as an open source application on GitHub. Harel developed the Python utility called ‘S3crets Scanner’ to aid in the quick identification of exposed secrets on public S3 buckets. It automatically completes the following tasks:

- Gets a list of public buckets using CSPM
- Uses API requests to display the bucket’s content
- Looks for any exposed text files
- Downloads the necessary text documents
- Looks for secrets in the content
- Sends outcomes to SIEM

Prior to downloading the text files for the ‘secrets scanning’ stage, the list is filtered to remove any buckets that were created with the intention of being made public. The Trufflehog3 tool, an enhanced Go-based variation of the secrets scanner that can check for credentials and private keys on GitHub, GitLab, file systems, and S3 buckets, will be used by the script while scanning a bucket to look at the text files’ contents.

Siren and ShadowDragon collaborate to enhance investigation solutions

A strategic partnership between Siren, a provider of investigative intelligence analytics, and ShadowDragon, a supplier of open source intelligence (OSINT) unique data sets and APIs, has been announced. This partnership will make it easier for modern investigations to find, gather, and sort open source data.

The Siren platform is used in search and discovery operations as well as investigation solutions all around the world. It conducts enterprise-wide search and offers sets of connections that make it possible to clearly visualise and explore relationships between records. The range of data types utilised in open source intelligence is supported by Siren.

Siren may now resell ShadowDragon data, making it possible to obtain the data through straightforward contracts. Both on-premises and cloud implementations of the offering are supported. Numerous customers in the United States, Europe, the